5 – Sicurezza di rete e qualità del servizio

La rete interna di Esplace costituisce l'infrastruttura comune dei sistemi descritti nei capitoli precedenti e, più in generale, delle attività del centro. In un ambiente aperto al pubblico deve conciliare requisiti di sicurezza e di qualità del servizio, in particolare per le applicazioni real-time come i giochi online.

Questo capitolo presenta un primo lavoro esplorativo di analisi e miglioramento della sicurezza e della qualità del servizio. L'obiettivo non è definire un'architettura definitiva, ma individuare alcune criticità concrete e introdurre misure di hardening e di QoS a basso impatto operativo sull'attività quotidiana.

5.1 Contesto e rischi principali

Dal punto di vista della rete, il contesto può essere riassunto in pochi elementi chiave. Sullo stesso segmento convivono postazioni di gioco accessibili al pubblico, server applicativi e postazioni amministrative: la presenza di utenti non autenticati su macchine gestite dal centro aumenta la superficie di attacco e rende necessario isolare i servizi critici e proteggere i sistemi interni, senza penalizzare l'esperienza di gioco.

Le postazioni dedicate al pubblico sono utilizzate esclusivamente per il gioco: i clienti accedono con i propri account alle piattaforme online e scaricano aggiornamenti e contenuti aggiuntivi, spesso in parallelo su molte macchine. Durante eventi e tornei il numero di client attivi e il volume di traffico crescono ulteriormente; eventuali problemi di rete si traducono immediatamente in lag, disconnessioni e, in generale, in un degrado evidente dell'esperienza di gioco.

Da questo scenario emergono tre macro-aree di rischio:

La prima riguarda gli **endpoint Windows esposti sulla LAN**: ogni PC client è un potenziale punto debole, perché può ospitare servizi non indispensabili, protocolli di discovery pensati per reti domestiche (LLMNR, mDNS, SSDP, WSD) e configurazioni di condivisione non sempre ottimali. La seconda area è il **perimetro di rete**, dove il gateway di frontiera svolge contemporaneamente il ruolo di router, firewall e punto di applicazione delle eventuali politiche di QoS; una configurazione errata potrebbe esporre verso la VLAN dei client interfacce di management o servizi pensati solo per reti amministrative, riducendo l'isolamento tra LAN interna, Wi-Fi pubblico e reti di servizio. Infine, la terza area riguarda la **qualità del servizio e la visibilità sul traffico**: download massivi, streaming e traffico non critico possono saturare la banda disponibile, con effetti diretti su latenza e jitter, mentre l'utilizzo di resolver DNS pubblici direttamente dagli host limita la possibilità di avere un punto centrale di osservazione e filtraggio delle richieste.

Il lavoro presentato in questo capitolo nasce quindi dall'esigenza di ottenere una fotografia realistica della situazione di partenza e di sperimentare alcune contromisure concrete, compatibili con la gestione quotidiana del centro.

5.2 Architettura logica della rete

Dal punto di vista logico, l'infrastruttura di rete di Esplace è composta da più VLAN collegate a un gateway **Fortinet** in configurazione HA (**High Availability**) che gestisce l'accesso a Internet e il filtraggio verso l'esterno. In questo capitolo ci si concentra in particolare sulla sottorete dedicata ai PC gaming, 192.168.X.0/24 (VLAN X). Per semplicità e per motivi di riservatezza, l'ultimo ottetto è rappresentato con la lettera X anziché con il valore reale. Su questa rete sono attestati esclusivamente i PC da gaming destinati al pubblico e il server Clonezilla utilizzato per il deploy massivo delle loro immagini. Il gateway 192.168.X.1, implementato sul firewall Fortinet, insieme agli switch Cisco dedicati, rappresenta il punto di uscita verso Internet e costituisce il perimetro principale tra questa LAN e l'esterno. In configurazione ordinaria il servizio DHCP della sala assegna indirizzi IP dinamici ai client e distribuisce come resolver DNS quello fornito dal provider (Vodafone), in modo da sfruttare le funzionalità di sicurezza offerte dal servizio DNS del provider senza dover gestire un'infrastruttura DNS interna dedicata.

Oltre alla VLAN dei pc gaming, la rete comprende ulteriori segmenti dedicati ai simulatori di guida, ai backend applicativi, alle postazioni amministrative e alla connettività Wi-Fi per il pubblico; anche questi sono collegati allo stesso gateway Fortinet, ma non rientrano nel perimetro delle misure descritte in questo capitolo, che si focalizzano sul dominio più esposto agli utenti esterni.

Il traffico che interessa questo capitolo può essere idealmente suddiviso in due grandi categorie. Da un lato il traffico interno alla LAN, ad esempio quello generato dal server Clonezilla verso i PC gaming durante le operazioni di imaging. Dall'altro lato il traffico in uscita verso Internet, che include i flussi di gioco online, i client di distribuzione digitale e la normale navigazione. Le analisi di sicurezza e le prove di QoS descritte nei paragrafi successivi si sono concentrate proprio su questa sottorete e su alcuni host ritenuti rappresentativi, in particolare il gateway e un endpoint Windows tipico.

5.3 Vulnerability assessment interno e prime misure di hardening

Per valutare lo stato di sicurezza della rete interna è stata condotta una breve attività di vulnerability assessment da una macchina di analisi collegata alla stessa VLAN dei client. L'intento non era quello di svolgere penetration test completi, ma di raccogliere informazioni sui servizi effettivamente esposti sulla LAN, misurare quanto gli host rispondano a protocolli legacy e individuare alcune opportunità di hardening a basso impatto.

Metodologia

Lo strumento principale utilizzato per l'analisi è stato **Nmap** [5], un tool open source per il port scanning e la ricognizione di rete. La scansione è stata eseguita in tre passaggi: inizialmente un "ping sweep" sull'intera 192.168.0.0/16, per individuare quali indirizzi fossero effettivamente attivi; in seguito una scansione delle porte TCP, con rilevazione dei servizi e delle versioni (`-sS -sV`), su una selezione di host ritenuti più interessanti; infine l'esecuzione di script NSE sugli host individuati.

Per la fase di discovery è stato utilizzato, in particolare, il comando:

```
sudo nmap -sn -PE -PS80,443,3389 192.168.0.0/16 --min-rate 200 --max-retries 2
```

Un estratto dell'output è riportato in *Figura 11* e mostra, tra gli host attivi, il gateway Fortinet (192.168.X.1), un endpoint Windows (192.168.X.219) e lo switch Cisco utilizzato come switch di accesso alla VLAN X.

```
└─$ sudo nmap -sn -PE -PS80,443,3389 192.168.0.0/16 --min-rate 200 --max-retries 2
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-08 13:02 UTC
Nmap scan report for 192.168.[redacted].1
Host is up (0.00015s latency).
MAC Address: 80:80:2C:A9:FD:FE (Fortinet)
Nmap scan report for 192.168.[redacted].219
Host is up (0.00063s latency).
MAC Address: D8:BB:C1:68:CB:26 (Micro-Star Intl)
Nmap scan report for 192.168.[redacted]
Host is up (0.0059s latency).
MAC Address: 00:24:C4:1E:6C:44 (Cisco Systems)
```

Figura 10 - Estratto della scansione Nmap utilizzata per la fase di discovery sulla LAN di Esplace.

Sugli host selezionati la scansione è stata completata eseguendo gli script NSE delle categorie **default** e **vuln** (`--script=default,vuln`). L'utilizzo di plugin potenzialmente più invasivi è stato ritenuto accettabile perché le postazioni analizzate non erano in uso durante i test ed era comunque disponibile un'immagine aggiornata per un eventuale ripristino tramite il sistema di deploy descritto nel Capitolo 3.

Per completare il quadro sono stati utilizzati anche strumenti come **nbtscan**, impiegato per raccogliere alcune informazioni di base sugli host Windows (ad esempio nome macchina e workgroup), e **smbclient**, utile per verificare il comportamento dei servizi SMB e controllare l'assenza di condivisioni accessibili in modo anonimo o con credenziali deboli.

Risultati principali

L'analisi di un endpoint Windows rappresentativo (192.168.X.219) ha evidenziato la presenza di un servizio HTTP in ascolto sulla porta 80, basato su Microsoft-IIS/10.0, che non è necessario al normale utilizzo della postazione di gioco. Le scansioni hanno inoltre confermato il supporto alle versioni moderne di SMB (SMBv2/v3), con SMB signing abilitato ma non richiesto; si tratta di una configurazione che non rappresenta una vulnerabilità immediata, ma che non garantisce piena protezione nei confronti di potenziali attacchi man-in-the-middle su segmenti particolarmente sensibili. Sempre sullo stesso host è stata rilevata la presenza di diversi protocolli di discovery tipici di ambienti domestici, come LLMNR, mDNS, SSDP e WS-Discovery. Questi protocolli generano traffico di broadcast e multicast e, in alcuni scenari, possono essere utilizzati per attacchi di tipo credential relay [3,5].

Dal punto di vista dei servizi di condivisione file, i tentativi di accesso SMB senza credenziali o con credenziali errate sono stati rifiutati, confermando l'assenza di condivisioni guest indiscriminatamente accessibili. Un estratto della scansione specifica sulla porta 445/TCP è riportato in *Figura 12* e mostra il risultato dello script `smb2-security-mode`, secondo cui la firma dei messaggi SMB risulta *"enabled but not required"*[5]*:* la funzionalità di firma è supportata e può essere utilizzata dai client, ma non è obbligatoria e i pacchetti privi di firma vengono comunque accettati. Di conseguenza il traffico SMB è solo parzialmente protetto da questa misura e rimane, almeno in teoria, più esposto ad attacchi di tipo man-in-the-middle rispetto a una configurazione in cui la firma sia richiesta per tutte le connessioni.

```
└─$ nmap -p445 --script smb2-security-mode 192.168.[redacted] 219
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-08 16:01 UTC
Nmap scan report for 192.168.[redacted].219
Host is up (0.00037s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: D8:BB:C1:68:CB:26 (Micro-Star Intl)

Host script results:
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required

Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds
```

Figura 11 - Output dello script Nmap smb2-security-mode sull'endpoint Windows 192.168.X.219

Un secondo filone di analisi ha riguardato l'apparato di rete Cisco che abbiamo nominato precedentemente. Su questo dispositivo una scansione con Nmap comprensiva di script *vuln* ha mostrato l'esposizione delle porte 23/tcp (Telnet) e 80/tcp (HTTP) con alcune criticità. L'interfaccia HTTP, erogata da una web-GUI legacy, è risultata vulnerabile a un attacco di tipo Slowloris (*Figura 13*), con la possibilità di esaurire le connessioni del web server mantenendo aperte numerose richieste parziali; si tratta di un potenziale denial of service che colpisce il piano di management più che il traffico di inoltro. Lo script `http-method-tamper` ha inoltre segnalato una vulnerabilità di tipo *"Authentication bypass by HTTP verb tampering"* su una risorsa HTTP protetta, ossia la possibilità, in determinate condizioni, di aggirare i controlli di accesso modificando il metodo HTTP utilizzato. In combinazione con i risultati dello script `http-auth`, che indicano l'uso di Basic Auth per l'accesso all'interfaccia, questo suggerisce una configurazione non ottimale del meccanismo di autenticazione dell'apparato.

```
| http-slowloris:
|   Vulnerable:
|   the DoS attack took +2m13s
|   with 1001 concurrent connections
|_  and 18 sent queries
```

Figura 12 – Output della scansione Nmap che evidenzia la vulnerabilità del servizio HTTP a un attacco Slowloris.

Sul versante Telnet il servizio risulta accessibile e richiede due coppie di credenziali distinte per l'accesso, ma non supporta alcuna cifratura: in caso di intercettazione del traffico, username e password verrebbero trasmessi in chiaro (*Figura 14*).

```
└─$ nmap -p23 192.168.[redacted]
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-08 16:00 UTC
Nmap scan report for 192.168.[redacted]
Host is up (0.00068s latency).

PORT   STATE SERVICE
23/tcp open  telnet
MAC Address: 00:24:C4:1E:6C:44 (Cisco Systems)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

Figura 13 - Output della scansione Nmap che mostra la porta 23/TCP (servizio Telnet) in stato open sull'host analizzato.

Queste criticità non impattano direttamente sui flussi di gioco, ma riguardano il piano di gestione dell'infrastruttura di rete: un attaccante che fosse già presente sulla LAN potrebbe provare a sfruttarle per prendere il controllo dell'apparato o per degradarne il funzionamento.

Prime misure di hardening

Sulla base delle evidenze raccolte è stato definito un piccolo insieme di interventi, applicati inizialmente a macchine e apparati di test.

Per quanto riguarda gli endpoint Windows, è stata valutata la disattivazione del servizio IIS sulle postazioni di gioco, oppure la sua limitazione a soli contesti di amministrazione; in ogni caso è stata considerata non desiderabile la presenza del metodo HTTP TRACE su host accessibili al pubblico. Sul fronte SMB è stata confermata la disabilitazione di SMBv1 e, partendo dall'osservazione che la firma dei messaggi è "enabled but not required", si è ipotizzata la possibilità di rendere obbligatoria la firma almeno per segmenti o categorie di client più sensibili, bilanciando l'aumento di overhead con il guadagno in termini di sicurezza.

Un secondo gruppo di interventi ha riguardato i protocolli di discovery. Su un endpoint di riferimento sono state disattivate LLMNR e alcune funzionalità di discovery non indispensabili; per mDNS, SSDP e WSD si è valutato di limitarne l'uso ai soli dispositivi che ne hanno reale necessità, come alcune stampanti o apparati specifici, eventualmente filtrando il relativo traffico a livello host o firewall.

L'apparato Cisco utilizzato come switch di accesso ha evidenziato sia vulnerabilità legate all'interfaccia web (Slowloris e verb tampering) sia l'uso di Telnet non cifrato per la gestione remota. Considerato lo stato di obsolescenza del dispositivo, invece di intervenire puntualmente sulla sua configurazione si è scelto di programmare la sua sostituzione con uno switch più recente, cogliendo l'occasione per migrare la gestione remota a SSH, limitare l'accesso alle interfacce di management a una rete di amministrazione dedicata ed eliminare, dove possibile, la web-GUI legacy.

Queste misure rappresentano un primo passo verso l'hardening dell'infrastruttura: non mirano a eliminare ogni rischio, ma a ridurre la superficie di attacco e a evitare che apparati o servizi non più attuali diventino l'anello debole della rete.

5.4 Prime prove di QoS e osservazioni

Oltre agli aspetti di sicurezza, per un centro Esports è fondamentale garantire stabilità e bassa latenza alle applicazioni di gioco, soprattutto in presenza di traffico concorrente. Dal punto di vista logico il traffico può essere suddiviso in poche categorie: i flussi real-time sensibili, come i giochi online e le sessioni sui simulatori; il traffico generato dai servizi interni, ad esempio i server di gioco o il sistema di deploy; il traffico bulk o non critico, composto da download di aggiornamenti, streaming e navigazione generica; e infine il traffico amministrativo utilizzato per la gestione degli apparati.

Nel caso di Esplace, il firewall Fortinet utilizzato come gateway integra già un insieme di policy di QoS predefinite, basate su code di priorità e limiti di banda per singolo client. In questa fase non si è intervenuti in maniera invasiva sulla configurazione, ma ci si è concentrati sulla verifica empirica del comportamento della rete in condizioni di carico elevato, per capire se le policy esistenti fossero sufficienti a mantenere un'esperienza di gioco stabile.

A tal fine è stato realizzato un semplice script PowerShell che avvia in modo automatizzato lo Speedtest CLI di Ookla su un numero elevato di postazioni gaming, fino a coinvolgere di fatto l'intero parco di circa cento PC. In questo modo è stato possibile generare, per brevi intervalli, una situazione di saturazione controllata della banda in uscita, mantenendo al contempo alcune postazioni destinate al gioco o al monitoraggio dei parametri di rete (ping, jitter, perdita di pacchetti).

Le prove hanno mostrato che, anche durante i picchi di traffico generati dagli speed test simultanei, la QoS configurata sul Fortinet riusciva a ripartire in modo equilibrato la banda disponibile tra i client, evitando che poche postazioni saturassero completamente il collegamento. Dal punto di vista dei giocatori non sono stati osservati episodi significativi di lag o disconnessioni aggiuntive rispetto alla situazione ordinaria; le misure puntuali di latenza e jitter raccolte in parallelo hanno evidenziato oscillazioni contenute e comunque compatibili con l'uso di giochi online.

Questi risultati non rappresentano una caratterizzazione esaustiva della QoS, né sostituiscono misure sistematiche con serie storiche di latenza, jitter e throughput, ma suggeriscono che le policy esistenti del gateway sono già adeguate a gestire scenari di carico intenso tipici della sala. In prospettiva, una possibile evoluzione potrebbe prevedere l'introduzione di marcature DSCP a livello di host, ad esempio tramite le policy di QoS di Windows (cmdlet New-NetQosPolicy [3]), e di classi di priorità più mirate per singole applicazioni di gioco, da valutare alla luce dei carichi reali e delle esigenze operative del centro.